

A governed foundation. KYC as the first domain.

Detailed Azure implementation plan

United States deployment and policy scope

FOUNDATION	Contracts, compiler, Case ledger, workflow, evidence, gateways, identity and operations
KYC DOMAIN	Eight configurable roles, screening, ownership, investigation, QA and human review
DELIVERY	Controlled pilot in week 16; production readiness decision in week 20
AZURE BASELINE	Private regional stamp; proposed East US 2 primary and Central US recovery

Planning baseline | Version 1.0 | 17 September 2026

Based on architecture.pdf and Addendum.pdf. Azure configurations and capacity values are proposed; the package does not provision resources or establish production compliance.

Contents

Purpose and use	3
1. Scope, assumptions, and decisions	4
2. Architecture and authority boundaries	5
3. Azure compatibility gates and implementation choices	6
4. Landing zone and resource organization	7
5. Network, private DNS, and traffic configuration	8
6. Identity and least privilege	10
7. Azure service configuration baseline	11
8. APIM gateway and adapter behavior	12
9. Canonical data model and transaction design	13
10. Evidence durability, retention, and lineage	14
11. Durable workflow, messaging, and budgets	15
12. Compiler, registry, and release construction	16
13. Generic executor, context, and policy services	17
14. KYC domain model and lifecycle	18
14A. United States policy implementation overlay	19
15. The eight KYC roles as configurable capabilities	20
16. KYC policies, commands, and gates	21
17. Human review and operational user experience	22
18. Engineering repository and delivery pipeline	23
19. Sequenced foundation implementation backlog	24
20. Sequenced KYC implementation backlog	25
21. Milestones, staffing, and critical path	26
22. Test, evaluation, and acceptance plan	27
23. Observability, service targets, and capacity	28
24. Resilience and disaster recovery	29
25. Cost, rollout, and operational ownership	30
26. Risks and production readiness checklist	31
27. Source traceability and implementation refinements	32

Purpose and use

Recommended delivery: build a reusable, governed Harness Factory foundation and deploy KYC as its first domain package. Target a controlled pilot in week 16 and a production readiness decision in week 20, conditional on the assumptions and gates below. Azure provisioning, application implementation, and production approval are future work; this package supplies the implementation design, configuration baseline, delivery backlog, and acceptance criteria.

Scope confirmed: USA. The proposed Azure region pair remains East US 2 / Central US pending availability and data-policy validation.

Source treatment: architecture.pdf (64 pages) supplies the logical design; Addendum.pdf (39 pages) supplies the proposed Azure mapping. Their imperative language is treated as architecture input, not as instructions to perform cloud changes. Examples, versions, budgets, product statements, and embedded citation tokens in those PDFs are not independently authoritative. This plan separates source requirements, recommended implementation decisions, and unresolved business inputs. Microsoft documentation was checked on 17 September 2026 for the cited platform constraints; actual subscription quotas, licenses, regional availability, and deployed configurations have not been inspected.

Deliverables in this package: this editable plan, a PDF rendition, a foundation Azure configuration specification, a KYC configuration specification, an illustrative APIM policy, a transaction algorithm, and a sequenced CSV backlog. YAML files are planning schemas, not Azure-native deployment templates. Examples contain placeholders and are not production-ready infrastructure.

1. Scope, assumptions, and decisions

The foundation includes contracts, compiler, signed registry, release management, canonical Case Service, command gateway, workflow kernel, capability resolution, context assembly, agent executor, policy enforcement, evidence, flight recorder, human-task APIs, evaluation, identity, networking, operational monitoring, and recovery. KYC includes all eight logical roles, entity identification, ownership relationships, sanctions/PEP screening, internal and external research, investigations, policy interpretation, recommendation, independent QA, human review, disposition, periodic review, and material-change rescreening.

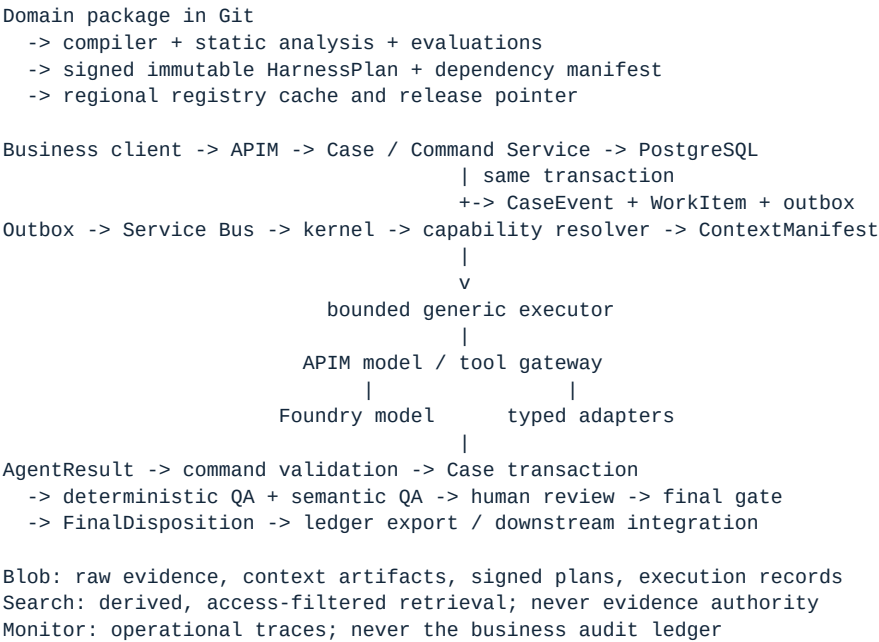
Launch scope is one business unit and a United States jurisdiction overlay, reflecting the user's confirmed USA scope. Individuals and legal entities are represented from the start; complex ownership cases route to analysts until the relevant policy and evaluation gates pass. Automated regulatory filings, account blocking, customer communications, transaction monitoring, fraud production packages, and global tenant rollout are outside this release. A tiny synthetic second-domain package is included only to prove foundation reuse.

ID	Planning assumption / required decision	Owner and deadline
D01	One Entra workforce tenant; separate production and nonproduction subscriptions; existing hub/SOC reused where available	Enterprise architecture, week 1
D02	USA scope confirmed by the user. Illustrative primary eastus2 and recovery centralus; U.S. processing and storage proposed within that scope. Validate both against contracts and every selected service before provisioning	Security and cloud platform, week 1
D03	Applicable U.S. federal/state/institution-specific rules, customer classes, products, ownership/control rules, risk appetite, and restricted outcomes remain business inputs	KYC policy owner, week 2
D04	1,000 cases/day; 10x hourly peak; average 12 agent executions/case; 2 MB source artifacts/case	Product and SRE, week 2
D05	Analyst-confirmed pilot: no automatic APPROVE or DECLINE. Subsequent low-risk automation requires separate release evidence	KYC operations, week 2
D06	Screening vendor, CRM/customer master, document repository, and approved external research provider not named; adapters start with mocks	Integration lead, contracts by week 3
D07	Retention schedule, legal hold scope, encryption-key requirements, and deletion authority are unresolved; no guessed statutory period	Records/security owners, week 2
D08	20-week estimate assumes 10-12 effective FTE and vendor/model access by week 3; calendar start is not committed	Delivery lead, week 1
D09	Regional Foundry model deployments preferred. Model name/version/quota remain evaluated selections, not hard-coded assumptions	AI lead, week 3
D10	Corporate private analyst access at launch. Internet customer intake, Teams publication, and delegated external identities are separate ingress designs	Product and security, week 2

All numeric sizes, thresholds, budgets, and SLOs in this plan are proposed engineering baselines unless explicitly attributed to a source. Policy fields marked UNSET block production compilation. The implementation can proceed with synthetic data while those inputs are resolved.

2. Architecture and authority boundaries

The core rule is preserved from architecture sections 1-7, 17-24 and 40: durable business truth lives in the Case and ledger; agents generate proposals through contracts. The runtime controls admission, workflow, resources, authorization, and final writes.



Boundary	Implemented authority	Must not become authority
Harness control plane	Signed plan digest, approval chain, immutable dependencies, revocation list	Mutable Git branch, agent inventory, live prompt editor
Case data plane	Current normalized aggregate, sequence, accepted facts, effective disposition	Model memory, conversation thread, vector store
Workflow	PostgreSQL WorkItems, leases, dependency results, durable timers, budget reservations	Queue delivery state or Logic Apps orchestration history
Evidence	Exact artifact version/hash and provenance; append-only corrections	Search snippet or unreferenced narrative
Decision	Authorized command after gates and required review	Decision Agent output alone
Enterprise governance	Entra principal inventory, Agent 365 cross-reference, SOC controls	Replacement for HarnessRegistry or per-case lineage

Recommended initial service boundaries are deliberately small: Case/Command Service; workflow service including scheduler/resolver; context/evidence service; generic executor; capability adapters; and control-plane compiler/release/evaluation workers. Keep modules separately testable without deploying every module as a microservice. KYC command handlers and schemas live in a versioned domain package loaded by the Case Service; the generic kernel contains no KYC role branches.

3. Azure compatibility gates and implementation choices

Foundry execution gate, week 2. Implement a spike with the generic executor in a Foundry hosted agent, a private APIM endpoint, and a private model resource. Demonstrate custom model routing through APIM, identity propagation, denial of direct model/tool routes, telemetry correlation, bounded execution/cancellation, and isolation from Case credentials. Inspect the actual API/SDK route; the presence of APIM in an architecture diagram does not establish mediation. If any required path cannot meet these controls, run the same executor container in an isolated Container Apps environment, using Foundry model deployments through APIM. Preserve Foundry Agent Service as an interchangeable adapter. Microsoft documents hosted-agent containers and dedicated identities; production suitability of the exact feature combination still requires the spike. [Microsoft: hosted agents](#).

Private network gate. Foundry private ingress and private outbound networking are separate configuration decisions. Provision the required agent subnet/data-proxy path and private endpoint DNS, and test both directions. Do not interpret a private resource endpoint as proof that all execution egress is controlled. [Microsoft: agent networking](#).

APIM baseline. Use established Premium classic with internal VNet deployment for the proposed production stamp, initially two units distributed across supported zones. Use Developer internal VNet only in development, with no production availability assumption. Premium v2 is a viable alternative after a separate network, policy, quota, and regional proof. Do not mix classic internal-injection settings with the v2 private-endpoint design in one template. APIM networking features differ by tier. [Microsoft: APIM networking options](#).

Model residency. Prefer regional Standard deployments when approved models are available. Permit Data Zone deployments only when the approved boundary is the whole data zone; disable Global deployments for this US-only planning baseline. A resource's region alone does not constrain inference processing. Record actual deployment type alongside endpoint, version, and attestation. [Microsoft: deployment types](#).

Deferred features. Agent 365/Entra Agent ID registration, Foundry IQ, managed MCP toolboxes, dedicated AI Gateway tiers, and hosted-agent guardrails must each have an explicit license, availability, support, and security decision. The core Case, workflow, authorization, and release controls remain operable without them. Do not copy the addendum's preview/GA claims into production policy without fresh verification.

4. Landing zone and resource organization

Use a management-group hierarchy with a platform branch for identity/connectivity/management and landing-zone branches for production and nonproduction. Establish policy assignments before workload deployment. Separate deployment identities by environment and component; release approvers cannot silently replace signing or infrastructure policy.

Subscription / group	Resource scope	Proposed contents
Platform connectivity	rg-hf-hub-us	Hub VNet, Azure Firewall, private DNS/Resolver, VPN or ExpressRoute, private CI agents
Platform management	rg-hf-ops-us	Central SOC links, policy initiatives, security monitoring and budgets
Harness control production	rg-hf-control-prod-eus2	Compiler/evaluation compute, registry PostgreSQL, ACR, signed artifact Blob, Key Vault, App Configuration
KYC production	rg-hf-net-prod-eus2	Execution VNet, delegated subnets, NSGs, UDRs, DNS links, APIM
KYC production	rg-hf-runtime-prod-eus2	Trusted platform Container Apps, isolated executor environment or Foundry, adapter compute
KYC production	rg-hf-data-prod-eus2	Case PostgreSQL, evidence/recorder storage, Service Bus, Search
KYC production	rg-hf-security-prod-eus2	Runtime Key Vault, identities, diagnostics and alert rules
KYC recovery	Corresponding groups in centralus	Warm recovery resources and replicated artifacts; writes disabled until recovery authority granted
Harness nonproduction	Per-environment groups	Dev and test; preproduction mirrors production topology at reduced capacity

Naming: {type}-hf-{component}-{env}-{region}-{ordinal}; storage names use a deterministic lowercase alphanumeric suffix to meet global uniqueness constraints. Required tags: owner, costCenter, environment, domain, dataClassification, residency, criticality, serviceId, managedBy, repository, expiry for temporary environments. Use opaque IDs, never customer names, in resource names and tags.

Policy initiative: allowed locations/SKUs; deny public data-plane access where supported; require TLS, managed identities, diagnostics and security configuration; disallow public storage and ACR admin credentials; restrict role assignments; require explicit exemptions with owner and expiry. Roll out audit first in sandbox, then deny in production after remediation. Use separate resource locks for critical databases, evidence accounts, keys, and networking; a lock is an operational guardrail, not WORM protection.

Register and validate resource providers for Microsoft.App, Network, ManagedIdentity, DBforPostgreSQL, Storage, ServiceBus, ApiManagement, CognitiveServices, Search, KeyVault, ContainerRegistry, AppConfiguration, Insights, OperationalInsights, EventGrid and optional Logic. Request vCPU, APIM, Foundry and model TPM/RPM quotas before application delivery depends on them.

5. Network, private DNS, and traffic configuration

Proposed non-overlapping ranges below are placeholders for enterprise IPAM approval. Recovery and nonproduction use different address ranges. Separate trusted platform, untrusted executor, and connector compute environments: subnet and identity separation must reinforce the application permission envelope.

Segment	Proposed CIDR	Configuration
Hub VNet	10.40.0.0/16	Peer to approved spokes; DNS forwarding; controlled enterprise routes
AzureFirewallSubnet	10.40.0.0/26	Firewall Standard baseline; Premium if TLS inspection/IDPS is approved
DNS inbound / outbound	10.40.1.0/28 and 10.40.1.16/28	Separate resolver subnets; managed-service delegation
Execution VNet	10.41.0.0/16	Private stamp; no overlapping enterprise networks
Trusted Container Apps	10.41.0.0/23	Delegate Microsoft.App/environments; internal environment
Executor Container Apps fallback	10.41.2.0/23	Separate internal environment, UDR and restricted identities
Connector Container Apps	10.41.4.0/23	Isolate approved vendor egress and secrets
APIM classic	10.41.6.0/24	Dedicated nondelegated subnet; internal VNet mode
Private endpoints	10.41.7.0/24	Nondelegated; endpoint NSG/route policy configured deliberately
Foundry agent subnet	10.41.8.0/23	Reserved; use delegation/sizing required by chosen Foundry mode
PostgreSQL delegated	10.41.10.0/26	Delegate Microsoft.DBforPostgreSQL/flexibleServers
Private build agents	10.41.11.0/26	No inbound internet; separate federated deploy authority
Optional Logic Apps integration	10.41.12.0/26	Dedicated subnet and required delegation if Standard is selected

Container Apps workload-profile environments require a dedicated subnet; the proposed /23 provides rollout and scale headroom above the documented /27 minimum. Enable zone redundancy when the environment is created; use minimum three replicas for critical APIs and kernel services, then verify distribution. [Microsoft: Container Apps zone redundancy](#).

Source -> destination	Ports and enforcement
Corporate analyst -> APIM and analyst UI	HTTPS 443 over VPN/ExpressRoute/private routing; Entra login and app roles
APIM -> Case/Context/Tool backends	HTTPS 443; backend accepts only gateway identity plus validated execution/user context
Trusted Case Service -> PostgreSQL	TLS 6432 for pool; 5432 for designated migration/admin paths
Executors -> APIM	HTTPS 443 only for business model/tool traffic; deny direct database, search, evidence and vendor access
Kernel/dispatcher -> Service Bus	AMQP TLS 5671 or explicitly selected AMQP-over-WebSockets 443

Source -> destination	Ports and enforcement
Context/evidence services -> Blob/Search	Private HTTPS 443; RBAC and tenant/object authorization
APIM model backend -> model account	Private HTTPS 443 with managed identity; no model keys
Connector -> approved vendors	HTTPS 443 through firewall FQDN allowlist, vendor scopes and static egress IP where needed
Runtime -> required Azure platform services	Documented service dependencies, identity/token, registry, DNS and monitoring routes only

UDRs send approved nonprivate egress to Firewall. Add service-specific exceptions needed by APIM/Container Apps/Foundry control planes; do not apply a blanket deny before validating platform dependency flows. NAT Gateway alone supplies translation and stable IPs, not a destination allowlist. Prevent same-VNet bypass by endpoint/subnet policy, application identity checks, and absence of resource data roles on executor identities.

Central private zones: `privatelink.blob.core.windows.net`, `privatelink.vaultcore.azure.net`, `privatelink.servicebus.windows.net`, `privatelink.search.windows.net`, `privatelink.azurecr.io`, `privatelink.azureconfig.io`, and model/Foundry zones returned by each endpoint's DNS configuration. Validate `privatelink.openai.azure.com`, `privatelink.cognitiveservices.azure.com`, and `privatelink.services.ai.azure.com` against actual resources. Link zones to every authorized VNet; configure on-premises conditional forwarding through DNS Resolver.

For internal Container Apps, configure the environment's generated default-domain private zone with apex/wildcard records to its internal VIP as required. Set an internal APIM custom domain with certificate rotation. PostgreSQL uses a private DNS zone ending in `.postgres.database.azure.com` for the selected delegated networking mode. Do not simultaneously configure a delegated-subnet database and the alternative Private Link networking design; Microsoft treats these as distinct connectivity options. [Microsoft: PostgreSQL private networking](#).

Network acceptance tests run from corporate access, private CI, trusted runtime, executor, and an untrusted public runner. Verify both successful authorized calls and failed public, cross-tenant, direct-model and direct-data access. DNS resolution to a private IP is necessary but insufficient evidence of enforcement.

6. Identity and least privilege

Human Entra app roles: KYC.Analyst, KYC.SeniorReviewer, KYC.PolicyAuthor, KYC.PolicyApprover, Harness.ReleaseApprover, Harness.Operator and KYC.Auditor. Enforce separation of author/approver and preparer/final reviewer on high-risk cases. Conditional Access requires the organization's approved MFA/device controls. PIM governs privileged Azure/database operations; emergency access is tested and audited.

Principal	Allowed resource access	Application restriction
mi-hf-case	Entra PostgreSQL role for Case command procedures; no cloud-wide Contributor	Only service able to commit business state; tenant scope from trusted identity
mi-hf-kernel	Workflow schema routines, Service Bus receiver as needed	May lease/schedule, cannot issue effective disposition directly
mi-hf-outbox	Outbox routines and Service Bus Data Sender at selected queues; event publication role if used	Publishes committed IDs only
mi-hf-context	Authorized read APIs, Blob Data Reader and Search Index Data Reader where needed	No arbitrary caller-supplied tenant filter; no final write
mi-hf-evidence	Narrow Blob write/read permissions and evidence registration APIs	Cannot overwrite accepted artifacts or decide facts
mi-hf-apim-model	Cognitive Services OpenAI User on selected Azure OpenAI backend, or exact inference role for selected Foundry backend	No Case data; roles tested for actual endpoint API
mi-hf-apim-tools	Invoke adapter APIs	Does not share model backend or vendor credentials unnecessarily
mi-hf-connector-{vendor}	Key Vault Secrets User at approved vault/secret scope or vendor OAuth	Fixed vendor routes and request/response schemas
mi-hf-agent-{role}	APIM application permission only; Foundry identity mapping if hosted	No Case DB, Blob, Search, model-resource or signing roles
mi-hf-qa	QA API permission with scoped context	No ability to approve its own recommendation or resolve its own blocking issue
mi-hf-release	Registry write, App Configuration Data Owner at release store, narrow signing operation	Cannot modify domain policy without separate approval
mi-hf-ci-{env}	Federated deploy role limited to target groups	Separate scoped role-assignment stage; no standing Owner
mi-hf-audit-export	Read audit metadata, write export container	No update/delete to ledger or evidence

Azure RBAC controls resource access; Entra app roles and application authorization enforce capabilities, tenant, case, purpose, and data class. No per-field business authorization is assumed to come automatically from Azure RBAC. A shared service identity with PostgreSQL RLS remains dependent on trusted application context; dedicated tenants use separate data and compute identities where the contract requires stronger isolation.

The executor authenticates to APIM with Entra. The kernel issues a short-lived signed execution token with principal ID, tenant, case, WorkItem, plan hash, capability allowlist, fencing epoch, expiry and audience. The capability backend validates this token against caller identity and authoritative WorkItem state. APIM strips caller-supplied identity headers, validates ingress tokens, then uses its own identity for the backend. Original identity survives only in a verified token/context; an arbitrary X-Tenant header is never trusted.

7. Azure service configuration baseline

The companion `config/foundation.azure.yaml` is the consolidated parameter specification. Values below are starting capacity, not measured capacity commitments.

Service	Production baseline	Development / test
Container Apps	Separate trusted/executor/connector workload-profile environments; internal networking; zone redundancy; critical services 3-10 replicas, 1 vCPU/2 GiB start	0-2 replicas; same trust boundaries; synthetic data
APIM	Premium classic, internal VNet, 2 units across supported zones; Entra; managed identity; diagnostics without bodies	Developer internal VNet; preprod uses production SKU for acceptance
Case PostgreSQL	Flexible Server, PostgreSQL 16 candidate; General Purpose D4ds_v5 candidate, 4 vCores; 256 GiB; zone-redundant HA; 35-day PITR	General Purpose 2 vCore candidate, 128 GiB; 7-day PITR; HA off in dev
Control PostgreSQL	Separate server/database authority; General Purpose 2 vCore candidate, 128 GiB; zone HA in prod	Small General Purpose; reduced backup
Storage	GPv2, ZRS primary; separate evidence, execution, release, quarantine accounts; approved DR copies; private access	LRS; short synthetic-data retention
Service Bus	Premium 1 messaging unit start; private endpoint; local/SAS auth disabled; Entra data roles	Premium for network parity; reduced hours/capacity
AI Search	Standard S1, 1 partition, 3 replicas candidate; private endpoint; RBAC; key auth disabled	Basic/Standard sized to supported features; test filters unchanged
Key Vault	Standard for connector secrets; Premium if HSM-backed release signing or CMK is selected; purge protection, 90-day soft delete	Separate vaults and synthetic keys
ACR	Premium private endpoint; admin disabled; images by digest; signed provenance; retention excludes released digests	Same registry feature requirements, smaller artifact set
App Configuration	Standard private endpoint; Entra; release pointers and kill-switch configuration	Separate labels/stores, no prod pointer permissions
Foundry/models	Per environment and isolation class; approved regional model deployments; private ingress/egress and Entra	Synthetic workloads; experimental features isolated
Monitor	Workspace-based App Insights and regional Log Analytics; 30-day operational retention proposal	14-day proposal; exclude real PII
Logic Apps	Optional Standard for connectors requiring VNet reachability; separate storage and identity	Mock adapters first
Event Grid	Optional outbound integration publication from outbox; narrow identities and dead-letter storage	Not required for canonical workflow readiness

PostgreSQL: Entra-only authentication; TLS certificate verification; private FQDN; managed-identity token refresh before opening new pooled connections. PgBouncer transaction pooling on 6432 is a candidate; verify driver/prepared-statement behavior and Entra support. Use direct connections for migrations, not worker paths. Set workload roles' statement timeout to 15 seconds, lock timeout to 2 seconds, and idle-in-transaction timeout to 30 seconds as initial application limits. Explicitly configure approved extensions only; pgvector is deferred unless a case-local retrieval need justifies it. [Microsoft: PgBouncer](#).

Keep aggregate app-side pools below a tested connection ceiling (start 160 pooled server connections across the stamp, reserve administrative headroom, verify server limits). Use parameterized SQL. Emit duration/error metadata without full SQL parameters. Schedule maintenance off business peak and test reconnect behavior during HA failover. Database SKU, engine support and region inventory are week-1 deployment checks, not verified by this planning artifact.

8. APIM gateway and adapter behavior

Expose versioned API groups: /cases/v1, /commands/v1, /work/v1, /context/v1, /tools/v1/{capability}, /models/v1/{profile}, /reviews/v1, and /audit/v1. Gateway routes point to fixed approved backends; clients cannot supply arbitrary URLs or backend IDs.

Policy order: correlation ID -> Entra token validation -> size/content-type/schema constraints -> coarse app-role check -> rate limit -> backend routing/managed identity -> response sanitization. The backend validates the signed execution envelope, tenant/case authorization, policy state, cost reservation, command preconditions and idempotency. Keep business outcome rules in the policy/Case layer.

APIM validates tenant and audience explicitly. For managed-identity backend authentication, use the exact backend token audience and verify accepted role claims. The illustrative XML supplied with this package covers authentication and routing only; it is not a complete authorization policy. [Microsoft: validate Entra token](#), [Microsoft: managed identity backend authentication](#).

Proposed initial ingress ceiling: 60 requests/minute/principal for commands, with separate workload identities for batch execution. Runtime hard budgets remain authoritative because gateway counters are not a transactional case budget. Model profiles initially cap output at 4,000 tokens and normal context at 24,000 tokens; the assembler rejects an oversized mandatory evidence set rather than silently omitting it. All limits are revisited after golden-case evaluation.

Model gateway records deployment, model/version, prompt hash, usage, latency and policy outcome. Do not cache KYC prompt/response bodies across cases or tenants. Disable arbitrary fallback: only attested model/profile combinations in the same allowed processing boundary can be selected. Honor Retry-After for transient model throttling; do not repeat a tool side effect because a model retry occurred.

Tool adapter contract contains request/response schema, effect class, permitted data fields, vendor identity profile, jurisdiction coverage, dataset freshness rules, timeout and idempotency semantics. Start read-only vendors at an 8-second attempt timeout with at most two retries inside a 30-second call budget and jittered backoff. Separate EMPTY/SUCCESS from TIMEOUT, RATE_LIMITED, AUTH_FAILURE, INVALID_RESPONSE and PROVIDER_ERROR. Failures never become negative screening evidence.

Vendor credentials remain in the adapter process or credential broker; they are never included in model context or ToolResult. Use destination allowlists, response size caps, malicious-document handling, SSRF controls, and URL canonicalization on research adapters. Disable redirects to unapproved/private hosts. All communication, account update, or irreversible operations require effect-specific authority; unknown provider commit outcomes enter reconciliation rather than blind retry.

9. Canonical data model and transaction design

Case-plane schemas: case_core, case_ledger, workflow, assurance, execution, and integration. Control-plane schemas: harness_registry, harness_control. Separate production servers are proposed for control and Case planes. Strongly typed relational columns carry identifiers, state, versions and relationships; schema-validated JSONB carries controlled domain detail.

Table family	Required fields / constraints
cases	tenant_id + case_id composite key; domain/schema version; status; case_sequence; stamp; pinned plan/policy; timestamps
subjects / relationships	tenant/case scoped IDs; person/entity type; normalized and original values; revision; valid time; ownership/control edges with evidence
evidence / artifacts	source/provider/dataset/version; retrieved/effective time; exact Blob version; raw/normalized hash; trust; classification; retention; durability status
claims / facts	subject/predicate/value; originating evidence spans; claim method; fact acceptance policy; purpose; valid-time and recorded-time
findings / assumptions / contradictions	materiality, status, source refs, explicit resolution and actor; supersession rather than deletion
work_items / dependencies	capability; state; required outputs; deadline; attempt; lease_until; fencing_epoch; budgets; dependency predicates
command_receipts	unique tenant + semantic idempotency key; canonical request hash; accepted/rejected result; event refs
case_events	unique tenant/case/sequence; immutable payload/schema; actor; command/policy/evidence refs; prior hash and event hash
outbox / inbox	unique event/destination key; publish state; attempt/next time; consumer dedupe receipt
recommendations / gate_results / dispositions	snapshot and dependency digest; evidence/policy/QA refs; reasons; authority; effective status; version
execution_records / manifests	execution/work/trace refs; actual model and all dependency digests; input/output artifact refs; usage and outcome
review_tasks / actions	assignment/role; SLA; decision snapshot; optimistic revision; actor reason; override/waiver evidence

Every child foreign key carries tenant and case scope where applicable; indexes start with tenant for access paths. Use FORCE ROW LEVEL SECURITY on tenant tables and ensure runtime roles are neither owners nor BYPASSRLS. Set transaction-local tenant context from authenticated server context and reset safely with pooling. Test the actual production roles. RLS is defense in depth against application mistakes, not protection from a compromised database owner or unrestricted SQL in the trusted service.

Command commit algorithm: authenticate -> authorize -> validate contract -> verify evidence/durability -> calculate request digest -> begin transaction -> insert/dedupe semantic command receipt -> lock Case head briefly -> verify entity revisions, fencing token, policy and release revocation -> evaluate deterministic command rules -> write accepted state -> allocate event sequence(s) -> append ledger event(s) -> create/update WorkItems and outbox -> save command result -> commit. Publish only after commit. A reused idempotency key with a different request digest is rejected; an identical retry returns the stored result.

Never hold a database lock during a model/tool call. Agent proposals reference entity revisions. Commutative evidence appends may merge after validation; identity changes invalidate screening/findings/decision dependencies. Finalization locks the head, checks the complete current dependency digest and required gates, then commits disposition and events atomically. A stale reviewer action cannot finalize after new evidence changes the case.

10. Evidence durability, retention, and lineage

The addendum's illustrative runtime flow places Blob evidence after the Case transaction. Refine this for implementation: accepted evidence must not point to an artifact that has not yet been durably written. There is no atomic transaction spanning PostgreSQL and Blob.

Use a prepare/register protocol. Allocate an evidence ID and opaque tenant/case object key; upload to quarantine/staging; inspect content, hash the exact bytes and normalize without losing raw provenance; finalize the immutable content/version; read back metadata to confirm hash/length/version; then register evidence in a Case command. If the database commit fails, the object remains an orphan and is reconciled by retention-aware cleanup. If Blob fails, the evidence never becomes ACCEPTED. An asynchronous path can record PENDING, but pending evidence cannot satisfy a decision gate.

Separate accounts/containers for quarantine, accepted evidence, execution artifacts, signed releases, and ledger archives. Keep HNS disabled for this GPv2 baseline unless required and compatibility-tested. Enable blob versioning and version-level immutability on evidence/ledger containers where required. The accepted metadata binds the exact version, not just a mutable object URL. Corrections create a new evidence object with supersedes; trust labels survive OCR, extraction, translation, summaries and indexing.

Retention is a policy matrix by jurisdiction, record category, trigger event, business purpose, and hold. A closure-triggered retention obligation cannot be implemented solely with a fixed creation-date lifecycle. Record retain-until per artifact; extend before expiry when closure or hold requires it. Keep real-data ingestion blocked until the retention strategy is approved and configured. Prototype only with synthetic data and unlocked short policies.

Locked WORM periods and legal holds need deliberate operational control: they prevent deletion/changes until expiry or hold release as applicable. Use version-level holds where case-specific isolation is needed; a shared container hold can affect every case in that container. Do not promise that soft delete is equivalent to immutability or that a lock can be shortened later. [Microsoft: immutable storage overview](#), [Microsoft: version-scope policies](#).

The lineage service stores typed edges Evidence -> Claim -> Fact -> Finding -> Recommendation -> Gate -> Disposition, plus policy, actor and execution references. Auditors can reconstruct what was known at decision time and compare it with present knowledge. Case-local hashes use scoped identifiers; avoid cross-tenant existence leaks from globally deduplicated customer artifacts.

Append-only SQL permissions and hash chaining provide operational history and tamper evidence, but a privileged database administrator can still alter database data. Export signed, ordered ledger segments and manifests to independently controlled WORM storage; verify sequence completeness and hashes continuously. Store no business-critical history only in sampled telemetry.

11. Durable workflow, messaging, and budgets

PostgreSQL is authoritative for WorkItem states: PROPOSED, BLOCKED, READY, LEASED, RUNNING, WAITING_HUMAN, RETRY_SCHEDULED, COMPLETED, FAILED, CANCELLED and EXPIRED. AgentResult statuses are a separate vocabulary and map to kernel transitions; PARTIAL cannot satisfy required completion automatically.

Queues: `work.ready.screening`, `work.ready.search`, `work.ready.investigation`, `work.ready.decision`, `work.ready.qa`, and `work.ready.platform`. Human tasks live in the database; a notification queue wakes UI/integration consumers. Each queue has its own built-in DLQ, monitored explicitly. Queue routing is configurable capability grouping, not logic tied to eight agent names.

Proposed entity settings: duplicate detection enabled with a 10-minute window, 60-second message lock, `maxDeliveryCount 5`, 1-day TTL with dead-letter on expiration. Disable sessions initially for independent work; if case-ordered transport is required, use a separate session-enabled queue with a session-aware receiver. Enabling sessions does not replace Case transaction locks or fencing. Broker duplicate detection is supplementary and bounded in time. [Microsoft: Service Bus duplicate detection](#).

Message payload carries only opaque tenant/case/work IDs, dispatch generation, capability, deadline and correlation metadata, never raw PII. `MessageId` is `tenant:work:dispatch-generation`; a true republish of the same dispatch uses the same ID, while a newly scheduled retry increments generation to avoid suppression by the duplicate window. Semantic business idempotency remains stable across attempts.

Worker flow: receive -> load authorized WorkItem -> atomically acquire 90-second lease and increment fencing epoch -> renew lease every 20 seconds -> execute within deadline -> submit proposals with current epoch -> mark terminal result -> complete queue message. Stale workers cannot commit or invoke new effects. Crash after database commit but before queue completion returns stored results on redelivery. A sweeper republishes expired leases and READY rows without an active dispatch. Queue lock auto-renewal is bounded; long waits return to durable state.

Reserve case/work/model/tool budgets transactionally before dispatch or invocation. Start case cap at \$20, 200 tool calls and 30 minutes active machine time; screening \$1.50/20 calls/120 seconds and investigation \$5/20 calls/300 seconds are planning limits derived from source examples, not business commitments. Human waiting time has its own SLA and does not spend the active execution budget. Release unused reservations, reconcile actual metering, and allow one in-flight request's bounded pricing variance. Budget exhaustion blocks automatic progress and creates explicit review/escalation.

Retry taxonomy: transient read errors use bounded retry; schema/auth/policy errors fail without retry until corrected; unknown side-effect outcome becomes RECONCILIATION_REQUIRED; deadline/budget exhaustion routes to human or suspended work. Cancellation increments authority epoch and prevents new work; it cannot undo a vendor action already completed. Compensation is a new authorized, auditable operation.

12. Compiler, registry, and release construction

Define JSON Schema/OpenAPI contracts for HarnessSpec, HarnessPlan, AgentSpec, ExecutionProfile, AgentRequest/Result, WorkItem, BusinessCommand, CaseEvent, Evidence, Claim, Fact, Finding, Assumption, Contradiction, DecisionPacket, Recommendation, GateResult, Disposition, QAResult, ToolSpec/Request/Result, SkillSpec, PolicyBundle, PermissionEnvelope, ContextManifest, ExecutionRecord, EvaluationAttestation and MigrationSpec. Use semver and explicit compatibility rules; versions in the source PDFs are examples, not current implementation versions.

Compiler stages: safe YAML parse -> schema validation -> overlay resolution -> immutable dependency resolution -> capability qualification -> permission derivation -> data-flow/residency checks -> workflow/dependency analysis -> assurance compatibility -> budget/fanout limits -> migration compatibility -> canonical plan serialization -> digest. Reject floating latest refs, executable YAML tags, missing producers, cycles, unsafe side effects, unauthorized data flows and unreachable required outcomes.

Configuration resolution order follows the source: platform -> domain -> jurisdiction -> business unit -> tenant -> environment -> case policy context. Later layers may tighten limits; permission broadening requires a separately approved entitlement. Produce an explanation of each effective value. The same inputs and compiler version produce the same plan digest; timestamps/signatures are in an external attestation envelope rather than perturbing the canonical content.

Registry records immutable artifacts, compatibility, dependency edges, owner, signer, approvals, certification, lifecycle and revocation. Sign the digest with a dedicated Key Vault key using an approved algorithm and detached signature; workers verify against pinned public-key IDs and a current revocation snapshot. Key rotation does not invalidate historical verification material. ACR carries digest-pinned containers; Blob carries immutable domain/plan artifacts; PostgreSQL indexes metadata. App Configuration stores the active digest pointer, changed with an ETag precondition.

Existing Cases pin plan and policy snapshots. A normal pointer change affects new cases; migration of active cases requires an explicit event and compatibility check. Emergency revocation has precedence over pinning: stop new dispatches and revalidate in-flight commits against revocation/epoch state. Cache signed plans regionally so control-plane outage does not erase authority; define revocation freshness at 60 seconds for new work and fail closed if stale beyond the approved grace window.

13. Generic executor, context, and policy services

The executor accepts only a verified ExecutionProfile, leased WorkItem, ContextManifest reference, scoped execution token and deadline. It loads skills/prompts by digest, calls models and tools through fixed gateways, validates structured output, and emits AgentResult. It has no direct write or source-of-truth privileges. Framework selection is contained behind the executor contract; begin with one implementation to avoid duplicate runtime semantics.

Context assembly intersects selectors, purpose-of-use, actor authority, tenant/case scope, evidence trust, residency and budget. Partition trusted runtime instructions, signed domain procedures, controlled case values, and untrusted external content. Store what was included, redacted, excluded and truncated; missing mandatory context blocks execution. Retain exact permitted inputs or stable artifact references with hashes according to approved retention.

AI Search uses separate indexes per isolation class, with tenant/case/ACL/classification fields filterable. Query filters are generated by trusted code, not agent text; reauthorize every result before loading its canonical artifact. Include tenant/purpose/policy digest in any retrieval cache key. Index changes follow accepted evidence events; record freshness and reject stale policy versions. Search security filtering is an application design pattern, not an automatic tenant authorization boundary. [Microsoft: Search security filters](#).

Deterministic policy engine (recommended OPA/Rego or equivalent pinned engine) has four explicit namespaces: authorization, execution requirements, decision permissibility and interpretation scope. Policy interpretation can identify ambiguity and quote approved clauses but cannot override deterministic policy. Persist bundle/hash, normalized input refs, evaluated rules, fired rules and result. Return PASS, FAIL, UNKNOWN or ERROR; missing facts propagate UNKNOWN, not false/clear/pass.

Flight recorder captures model request/response artifacts where permitted, actual parameters, tool requests/results, proposal/acceptance receipts, context, policy evaluations and usage. Capture supplied data and observable outputs; do not require private model chain-of-thought. Replay has three modes: deterministic command/policy replay; recorded-tool/model simulation; and live model reevaluation. Live reevaluation is a new experiment and cannot be assumed bit-for-bit reproducible.

14. KYC domain model and lifecycle

The domain package supplies schemas, command handlers, policies, skills, tool bindings, evaluation datasets and state-machine configuration. Runtime mechanics remain shared. Maintain a KYC policy catalog linking each enforceable rule to an approved source clause, effective dates, owner and test cases. This is an implementation plan, not a determination of legal obligations.

Domain object	Implementation content
Person	Names/aliases/transliterations, date/place of birth where justified, addresses, nationality/residency, identifiers and document refs
Legal entity	Registered/trading names, registration number/jurisdiction, legal form, status, business activity, addresses and source refs
Relationship	Ownership percentages, direct/indirect paths, control roles, directors/representatives, valid dates and evidence; circular/unknown structures explicit
Customer profile	Product/channel/purpose, expected activity, source of funds/wealth requirements, jurisdiction exposures and policy-derived risk factors
Screening result	Query identity revision, provider coverage, dataset version/time, raw candidates, match assessment, disambiguating evidence, completion status
Review requirement	Policy rule, evidence type, due date, accepted producer, completion predicate, waiver authority if any
Decision packet	Snapshot, material facts/findings, unresolved assumptions/contradictions, failed tools, policy/risk/QA and evidence refs

Validate original versus normalized identity separately; retain transliteration method and source. Never resolve identity from a name match alone. Risk indicators are explicit policy inputs; model confidence is not a calibrated risk score. Beneficial ownership thresholds, indirect aggregation rules, control-person requirements, and document validity windows are jurisdiction/product configuration fields, left UNSET until approved.

Lifecycle: INTAKE -> VALIDATING -> SCREENING -> INVESTIGATING where required -> READY_FOR_DECISION -> QA_REVIEW -> HUMAN_REVIEW -> APPROVED / DECLINED. Parallel required work is represented as dependencies rather than a single sequential agent chain. NEEDS_INFORMATION and SUSPENDED are explicit states with reason codes and timers. HUMAN_REVIEW_REQUIRED is an effective routing disposition, not a successful onboarding outcome. CLOSED follows a permitted terminal business state and required archival/actions completion.

Post-approval, periodic review dates and trigger events create a new review episode linked to the customer and prior case. Triggers include identity/ownership changes, new relevant provider matches, risk/policy changes and expired evidence. A prior final disposition is preserved; new review creates a superseding effective record only through a fresh gate. Existing customer/account systems remain authoritative for account operations.

14A. United States policy implementation overlay

USA is confirmed; the institution type remains open. The following banking-oriented mapping is a design starting point for the policy owner, not an assertion that every rule applies to every KYC business. Bind each rule to institution, account/product, customer type, effective date and exception criteria before production use.

Customer identification: for a bank overlay, map 31 CFR 1020.220 into required identity fields, documentary/non-documentary verification, discrepancy resolution, customer notice evidence, and rules for unsuccessful verification. Track identifying-information retention separately from verification-method/document-description records: the regulation uses different five-year trigger events, including account closure versus record creation. An operational KYC case closing is not necessarily the account closing. Store account lifecycle events or a verified reference to them to calculate retention. [eCFR: bank CIP requirements](#).

Beneficial ownership: where the covered-financial-institution CDD rule applies, model ownership and control as distinct requirements. FinCEN describes a 25%-or-more ownership prong and a control individual; exclusions and exceptions require explicit applicability rules. This is a policy baseline to validate, not a universal threshold for every ownership analysis. [FinCEN: CDD rule](#).

Current account-opening relief: FinCEN's February 13, 2026 relief permits covered institutions to limit beneficial-owner identification/verification to first account opening, later facts calling prior information into question, and risk-based ongoing CDD needs. Adoption is optional. Implement `account_opening_relief_adopted` as an approved institution-level policy value; preserve prior-verification provenance and assess change triggers rather than blindly requiring complete recapture at every account. Test both adopted and non-adopted paths. [FinCEN: updated CDD FAQs](#).

Sanctions ownership: the OFAC 50 Percent Rule is separate from the CDD ownership threshold. Capture direct/indirect and aggregated blocked ownership and refer uncertain ownership paths for specialist resolution; simple name-list matching is insufficient. Never reuse a single configurable percentage for both CDD beneficial-owner identification and OFAC blocking analysis. [OFAC: FAQ 401](#).

U.S. overlay setting	Build requirement / release evidence
<code>institution_type</code> and <code>applicable_rule_catalog</code>	Required before production; bank/broker/other overlays cannot silently share all rules
<code>cip_notice_and_verification_policy</code>	Store notice/version/time and verification method/result; negative tests for missing or inconsistent identity
<code>cdd_ownership_prong</code> / <code>control_prong</code>	Independently configurable predicates and exclusions; ownership and control fixtures
<code>account_opening_relief_adopted</code>	Explicit true/false plus approval/date; first-account, changed-information and risk-trigger tests
<code>ofac_ownership_analysis</code>	Distinct policy namespace and provider scope; aggregation/indirect ownership expert-reviewed fixtures
<code>account_lifecycle_retention_trigger</code>	Subscribe to authoritative closure/dormancy events where applicable; distinguish case closure
<code>ongoing_monitoring_handoff</code>	Persist required customer-risk and review outputs to the existing AML program; full transaction monitoring remains outside this build

Corporate Transparency Act BOI reporting, financial-institution CDD collection, and OFAC screening must remain separate policy namespaces. Do not infer one obligation from another or assume this KYC release supplies the institution's entire AML program. The policy owner resolves applicable federal/state and product-specific requirements and approves the exact rule bundle.

15. The eight KYC roles as configurable capabilities

Role	Input and capabilities	Outputs / boundaries
Orchestrator	Case progress, unresolved questions, allowed work types; <code>work.plan</code>	Proposed work/decomposition and dependencies. Kernel validates cycles, authority, fanout and budget; no workflow state writes
Policy	Approved policy snapshots, structured applicability facts; <code>policy.interpret</code>	Clause-linked interpretation, ambiguity and conflicts. Cannot rewrite rule bundles or waive requirements
Screening	Identity snapshot, aliases, coverage rules; sanctions/PEP/adverse-media licensed queries	Raw evidence refs, candidate claims, findings and unresolved identity conflicts. Outage stays incomplete
Internal Search	Minimal identity selectors and authorized sources; <code>customer.internal.search</code> , <code>document.internal.retrieve</code>	Internal evidence with source ACL and effective time. No unrestricted cross-customer search/export
External Search	Minimal approved public identity fields; <code>research.external.search</code>	Source captures, provenance and adverse-media claims. No internal document or identifier exfiltration
Investigation	Bounded question, competing claims, gaps and materiality; approved internal/external research	Investigation steps, corroborated findings, assumptions, contradiction resolution proposals, residual uncertainty
Decision	Controlled DecisionPacket with current dependency digest; <code>decision.recommend</code>	Recommendation with reason codes and evidence/policy refs. Cannot create an effective disposition
QA	Independently assembled verification packet; <code>assurance.verify</code>	PASS/FAIL/UNKNOWN/ERROR, checks and rework proposals. Distinct principal/context; no self-approval

Deploy eight AgentSpecs against one executor implementation. Independent QA means separate authority and verification work, not simply a second prompt containing the Decision Agent's rationale. Use deterministic checks for existence, required work, freshness, exact references and policy; semantic QA examines whether evidence supports interpretation and whether adverse or contradictory material was omitted.

KYC skills: identity resolution; entity/ownership graph interpretation; screening candidate analysis; adverse-media relevance; evidence corroboration; policy applicability; bounded investigation; rationale composition; independent verification. Each has signed content, declared input/output schemas, invariants, tests and capability dependencies. Tool adapters remain separate from skills.

16. KYC policies, commands, and gates

Commands: CreateKycCase, RegisterSubject, AddRelationship, RegisterEvidence, ProposeClaim, AcceptClaimAsFact, RecordScreeningFinding, RaiseContradiction, ResolveContradiction, RecordAssumption, ProposeWorkItem, SubmitDecisionRecommendation, RecordQAResult, RequestHumanReview, RecordReviewAction, FinalizeDisposition, SchedulePeriodicReview and ReopenReviewEpisode. Only authorized policy/domain services or humans can accept facts and finalize; agent proposals do not bypass the acceptance step.

Condition	Required behavior	Automation boundary
Missing required identification	NEEDS_INFORMATION and explicit missing-evidence work	No approval; no invented values
Successful screening with no candidates	Record successful query and coverage/freshness metadata	May meet screening requirement, not all KYC requirements
Timeout, missing coverage, stale dataset	Retry within limits then suspend/escalate	Never treat as clear
Possible sanctions match	Identity investigation and specialist review	Block auto-approval while unresolved
Confirmed sanctions concern	Route to approved sanctions procedure	No generic automatic account action or filing
PEP candidate / confirmed PEP	Disambiguation and risk/EDD review per policy	PEP status does not itself imply wrongdoing or automatic rejection
Material adverse media	Verify identity, source, relevance and recency	Preserve uncertainty and source quality
Unknown ownership/control	Request evidence/investigation or analyst handling	No guessed beneficial owner
High materiality unverified assumption/open contradiction	Rework or review	Approval prohibited unless specific permitted, evidenced resolution/waiver applies
QA UNKNOWN or ERROR	Retry/rework where appropriate, then human review	Cannot silently convert to PASS
Policy conflict or expired policy snapshot	Policy-owner escalation	No prompt-based choice of permissive rule
Provider or model revoked	Stop affected dispatches; compute impacted cases	No uncertified failover

Finalization gate checks: authenticated final actor and separation of duties; current plan/policy authority; matching case/subject/dependency revisions; required work complete; accepted and fresh evidence with durable artifacts; no prohibited material uncertainty; applicable QA passed or approved review path satisfied; decision allowed by jurisdiction/product policy; budget/failure exceptions recorded; required human signatures present. Recompute deterministic checks in the same commit boundary as FinalDisposition. A gate result for an older snapshot cannot authorize a newer case.

Pilot policy explicitly requires a qualified human for APPROVE and DECLINE. Human override records reason, policy authority, evidence and snapshot; the UI cannot override nonwaivable prohibitions. Waiver permissions and expiry are typed policies, not a free-text bypass. If ongoing monitoring is required, finalization also creates the review schedule and integration outbox atomically.

17. Human review and operational user experience

Deliver a private analyst web application on the trusted application tier, integrated with Entra. Minimum screens: queue with priority/SLA, case identity/ownership view, evidence viewer with source and timestamps, contradictions/assumptions, decision packet, deterministic and semantic QA results, review action dialog and audit timeline. Provide source-page/span links and clear separation of original evidence, extracted claims and accepted facts.

The UI uses Case/Review APIs only. Analyst actions carry the review task revision and case dependency digest. A stale packet forces refresh and re-review. High-risk cases require a different senior reviewer where policy says so; the same person cannot self-complete both roles. Evidence downloads are authorized per request, short-lived if signed URLs are used, and audited; no public anonymous Blob access.

Proposed operational targets: ordinary review assigned within 4 business hours; urgent sanctions concerns routed within 15 minutes during the agreed coverage window; manager escalation on overdue tasks. These are staffing assumptions, not regulatory deadlines. Capture review lead time, disagreement, override causes and rework as product metrics. Notifications contain opaque case IDs and deep links, not sensitive evidence. Customer messages remain outside pilot automation.

18. Engineering repository and delivery pipeline

infra/bicep/	landing-zone integration and reusable Azure modules
infra/environments/	dev, test, preprod, prod, recovery parameters
contracts/	schemas, OpenAPI, compatibility fixtures
compiler/	parser, resolver, checks, plan serializer
registry/	immutable metadata, release and revocation APIs
runtime/	case, commands, workflow, context, executor, policy
adapters/	models, screening, research, CRM, storage, messaging
domains/kyc/	specs, skills, policies, schemas, evaluations, migrations
apps/analyst/	review UI and evidence navigation
tests/	contracts, integration, replay, faults, adversarial
ops/	dashboards, alerts, runbooks, recovery drills

Use Bicep as the recommended Azure IaC standard; Terraform is acceptable if it is already the enterprise standard, but choose one owner per resource. The supplied YAML is input to module design, not an alternate runtime portal configuration. Lock provider/API/module versions; use what-if and policy validation in private CI before apply. Do not let application releases silently alter networking, identity, retention or keys.

Deployment order: subscription/policy/RBAC bootstrap -> hub/spoke/DNS -> managed identities and Key Vault -> storage/ACR/PostgreSQL/Service Bus/Search -> private endpoints and security rules -> Container Apps environments/APIM/Foundry resources -> diagnostics -> database roles/migrations -> services/adapters -> signed domain artifacts -> APIM routes -> synthetic smoke tests -> traffic admission. Split role-assignment authority from normal deployment credentials. Use OIDC federation for CI, and private agents for data-plane steps.

Pipeline stages: lint/schema -> unit/contract compatibility -> compiler authority/data-flow checks -> policy tests -> adapter tests -> container build/SBOM/vulnerability scan -> golden/adversarial/fault evaluations -> attestation -> policy-owner and release approval -> sign -> deploy immutable images/agent versions -> preprod validation -> shadow -> canary -> active pointer promotion. Retain test data digests, tool/model versions and exceptions in the attestation.

Database changes use expand/migrate/contract. Deploy backward-compatible readers/writers, backfill in bounded batches, verify counts/hashes and only later remove old columns. Roll back traffic and release pointer without assuming a destructive database rollback is safe. Active WorkItems remain pinned; new contracts need a compatibility adapter or explicit migration event.

19. Sequenced foundation implementation backlog

Estimates are person-weeks of focused engineering, exclude waiting for procurement, and overlap only when dependencies allow. The CSV expands these rows into an importable work breakdown.

ID	Work package / owner	Effort	Dependency and completion evidence
F01	Architecture decisions, threat/data-flow model / architect + security	3	D01-D10 owners assigned; regional/service compatibility matrix accepted
F02	Landing zone, IaC, private CI and quotas / cloud platform	5	F01; repeatable dev deployment; policy and public-access negative tests
F03	Network/DNS and identity skeleton / platform + security	5	F02; private paths and executor bypass denial proven
F04	Contract suite and SDK / platform engineers	4	F01; version compatibility tests and reference fixtures
F05	Case/command/ledger and transaction boundary / backend + DBA	7	F03/F04; atomic state/event/outbox and stale/duplicate command tests
F06	Evidence ingestion/durability/retention / data engineer	5	F03/F04; no accepted dangling artifacts; hold/restore proof
F07	Kernel, scheduler, leases and budgets / backend	7	F05; crash/lease/fencing/retry/budget concurrency tests
F08	Compiler, registry, signing and revocation / platform + security	7	F04; deterministic build, unsafe package rejection, revocation enforcement
F09	APIM model/tool gateway and adapter SDK / integration	5	F03/F04; identity chain and no direct endpoint bypass
F10	Generic executor + Foundry compatibility proof / AI engineering	5	F04/F09; hosted path passes or Container Apps fallback selected
F11	Context, policy and assurance services / AI + backend	6	F05/F06/F08; trust partitions, RLS/filter tests, reproducible policy results
F12	Recorder, monitoring and security integration / SRE	4	F05-F11; complete audit export plus alerts without raw PII
F13	Evaluation/replay infrastructure / QA + AI	5	F04/F08/F10; layered evals, pinned fixtures and signed attestation
F14	Recovery, operations and platform acceptance / SRE + security	5	F05-F13; restore/reconcile/failover evidence and on-call handover

Foundation acceptance is an end-to-end synthetic case: compile/sign -> ingest -> durable work -> private model/tool call -> evidence -> accepted command -> QA -> human decision -> audit export -> recovery replay. A second synthetic domain must execute using new schemas/specs/handlers without editing generic scheduler/executor code.

20. Sequenced KYC implementation backlog

ID	Work package / owner	Effort	Dependency and completion evidence
K01	KYC rule catalog, lifecycle, risk and data schemas / policy + domain engineering	5	F01/F04, D03/D07; signed rule-to-test mapping; UNSET values tracked
K02	Intake and identity/ownership normalization / backend	4	F05/K01; valid/invalid individual and entity cases with provenance
K03	Screening adapter and skills / integration + AI	5	F06/F09/K01, vendor access; no-match/outage/alias/candidate fixtures
K04	Internal and external search / integration + AI	5	F09/F11; ACL, egress, source capture and injection tests
K05	Investigation and work-planning specs / AI + domain	4	F07/F10/K03/K04; bounded hypothesis/evidence/rework loop
K06	Policy interpretation and decision packet / domain + AI	4	F11/K01/K05; clause-linked rationale; deterministic rule authority preserved
K07	Independent QA and finalization gates / QA + backend	5	F11/K06; stale packet, unknown result and prohibited outcome blocked
K08	Analyst UI, task assignment and approvals / frontend + backend	5	F05/F07/K02; accessible review flow, evidence navigation, four-eyes tests
K09	Periodic review and downstream handoff / backend + integration	3	K07/K08; durable review schedule and idempotent integration
K10	Golden corpus, UAT and pilot / QA + operations	6	K02-K09/F13; adjudicated expected outcomes, measured defects and acceptance
K11	Runbooks, training and production readiness / operations + SRE	3	K10/F14; staffing, recovery, change controls and rollout approval

Proposed total: 73 foundation + 49 KYC = 122 engineering person-weeks. Add 20% contingency (approximately 24 person-weeks) for remediation and integration uncertainty, giving approximately 146 person-weeks. At 10 effective FTE this is roughly 15 elapsed delivery weeks before dependency and review delays; a 20-week plan includes those delays. Shared policy/security/operations time must be scheduled explicitly, not assumed free.

21. Milestones, staffing, and critical path

Window	Delivery milestone	Exit gate
Weeks 1-2	Decisions, threat model, contracts, quota requests, Foundry/APIIM spike	G0: residency, policy owners, runtime path, tenant isolation and release scope agreed
Weeks 3-4	Private dev foundation, identities, Case/ledger/evidence thin slice	G1: repeatable IaC and negative access tests; no atomicity gaps
Weeks 5-7	Kernel, gateway, generic executor, compiler/registry signing	G2: synthetic end-to-end run with retries, fencing, budgets and revocation
Weeks 8-10	KYC intake/screening/search/investigation; analyst UI begins	G3: representative person/entity cases and provider failure behavior pass
Weeks 11-13	Policy/decision/QA/review, periodic review, audit export	G4: no model-only final decision; stale evidence and forbidden outcomes blocked
Weeks 14-16	Preproduction load/security/recovery; shadow and controlled pilot	G5: adjudicated corpus/UAT pass; staffed analyst-confirmed pilot
Weeks 17-20	Pilot fixes, operations drills, measured canary, production decision	G6: signed readiness evidence, rollback tested, owners accept remaining limitations

Critical path: policy/vendor/model decisions -> private network/identity -> Case/evidence transaction -> workflow/gateway/executor -> screening/investigation -> decision/QA/human review -> end-to-end evaluation/recovery -> pilot. UI mockups, contract development, rule catalog and synthetic corpus can start in parallel; production rollout cannot bypass a late vendor or jurisdiction dependency.

Staffing baseline: technical lead/architect 1; cloud/SRE 2; backend/platform 3; AI/domain engineering 2; integration 1; frontend 1; QA/automation 1; plus allocated policy, security, DBA, product and KYC operations time. This is about 11 core FTE; adjust elapsed dates if actual capacity differs. Each gate has one accountable delivery owner and explicit security/domain sign-off rather than consensus-by-meeting.

22. Test, evaluation, and acceptance plan

Use synthetic/deidentified data first; any real evaluation dataset needs approved access, retention and residency. Build an adjudicated starting corpus of at least 300 cases stratified across individuals, entities, aliases/transliterations, near matches, missing IDs, ownership complexity, sanctions/PEP concerns, adverse media, conflicting evidence, stale sources and outages. This is an engineering starting point, not evidence of production-level statistical sufficiency. Two qualified reviewers resolve labeling disagreements for material outcomes.

Test layer	Required evidence / provisional gate
Contracts/compiler	All schemas/version fixtures pass; cycles, missing skills, forbidden egress and floating refs rejected
Transactions/idempotency	Crash at each commit/publish boundary; 100 duplicate deliveries yield one semantic effect; changed payload with same key rejected
Concurrency	Stale lease and stale human snapshot cannot finalize; simultaneous evidence append is safe; identity change invalidates dependents
Isolation	Cross-tenant IDs, cache keys, search filters, forged headers and direct resource calls denied using actual runtime principals
Evidence/retention	Hash/version matches; pending/missing artifacts block decisions; correction preserves provenance; holds and deletion tested in synthetic containers
Policy/gates	100% pass on defined deterministic prohibitions; zero unsafe approvals in the release corpus; UNKNOWN never treated as PASS
Screening/retrieval	Measure candidate recall/precision and retrieval relevance per cohort/vendor; policy owner sets minimum sensitivity and review-load thresholds
Semantic quality	Evidence-support, completeness and contradiction-handling rubric; no unresolved critical unsupported rationale in release set
Adversarial	Injected instructions in PDFs/vendor payloads/search snippets cannot grant tools, disclose secrets, change policy or approve cases
Failure and recovery	Model/vendor throttling, unavailable Blob/DB, revoked plan, queue redelivery, regional recovery and ambiguous side effects exercised
Performance	10x assumed average hourly intake for 60 minutes, then drain; case API and queue age meet targets without bypassing budgets
Human UAT	Representative analysts complete intake/research/rework/review/override-per-policy and audit retrieval; no high-severity usability blockers

Report numerators, denominators, confidence intervals and cohort slices for quality measures. A zero-error test set does not establish zero real-world false negatives. Model self-confidence cannot act as the release criterion. Separate screening provider quality, retrieval, model/skill interpretation, routing, policy, disposition and human disagreement metrics.

Reevaluate when model/version, prompt, skill, tool/dataset, policy, permission envelope, schema, compiler or context assembly changes. Attest the complete combination and scope. Replay stored tool/model results for deterministic regressions; live experiments never mutate historical case outcomes.

23. Observability, service targets, and capacity

Proposed SLOs: Case/Command API 99.9% monthly availability; p95 internal read/command latency below 500 ms excluding synchronous external dependencies; READY queue age p95 below 30 seconds during normal capacity; straight-through machine processing p95 below 5 minutes excluding human waits; 100% accepted mutations represented in the ledger and outbox; 100% effective dispositions have complete required decision lineage. These are application targets, not Azure contractual SLAs.

OpenTelemetry spans: harness.run, workflow.transition, context.assembly, agent.execution, model.inference, tool.execution, case.command, assurance.check and review.action. Correlate with opaque case/work/execution/command/trace IDs, plan/policy digests, deployment, version, outcome and cost. No raw identifiers, documents, access tokens or prompt bodies in general traces. Keep high-cardinality IDs in controlled logs/traces, not all metric labels.

Alerts: any critical audit sequence gap or unauthorized finalization; lease/fencing error surge; outbox oldest age over 60 seconds; work queue age over 2 minutes; any persistent DLQ entry; provider/model error rate over 5% for 5 minutes; database CPU above 70% for 15 minutes or storage above 80%; evidence/DR replication lag over budget; stale policy/revocation cache; model token/cost abnormality. Thresholds are proposed and tuned during preprod. Route to an owned action group/runbook with severity and escalation.

Keep security correlation in the enterprise SOC through Defender/Sentinel where licensed. Link Purview catalog assets to evidence source metadata; do not replace fine-grained case lineage. Add sensitive-log scanning to CI and runtime sampling. Durable execution/ledger capture is unsampled even when operational tracing is sampled.

Capacity model: 1,000 cases/day x 12 executions = 12,000 executions/day. At an assumed 24,000 input + 4,000 output tokens/execution, planning demand is 288 million input and 48 million output tokens/day; this intentionally conservative upper scenario should be reduced with measured selector sizes. Average is about 233,000 tokens/minute; a 10x burst approaches 2.33 million tokens/minute. Request quota with headroom and queue backpressure, not just autoscaling workers. API RPM and model-specific token accounting require separate checks.

At 30 seconds mean execution time, 12,000/day implies about 4.2 concurrent executions on average and 42 at 10x. Start max concurrent executor work at 50 per stamp, constrained further by model/vendor quotas and database capacity. Assuming 2 MB source artifacts/case yields about 60 GB/month raw growth before execution records, versions, replicas and retention. Measure these separately in pilot; defaulting to full 28k-token contexts on every call would create unnecessary cost.

24. Resilience and disaster recovery

Define recovery per record class, not one blanket RPO. Local zone HA and regional recovery are different. PostgreSQL HA synchronously protects committed state across supported zones; regional replicas and artifact copies require their own lag monitoring and recovery tests. [Microsoft: PostgreSQL HA](#).

Component	Proposed objective	Mechanism and limitation
Case/ledger/WorkItems	Zone event: RPO 0 target; regional RPO <=5 min, RTO <=4 h target	Zone HA + warm cross-region read replica; actual async lag measured; PITR 35 days for logical corruption
Accepted evidence	Regional RPO <=5 min target; decision-critical durability confirmed before effective disposition	App-managed verified copy to independent approved-region ZRS account; final gate requires copy receipt for cited evidence
Registry/signed releases	RPO 0 for published release; RTO <=1 h target	Publish only after digest-verified copies in both approved regions and usable verification keys
Execution recorder	RPO <=15 min target; decision-required artifacts stricter	Persist locally then copy; final decision waits for required artifact durability receipts
Queues	No canonical business loss after recovered DB reconciliation	Rebuild dispatches from database; pending transport may be replayed
Search	Rebuildable; RTO <=24 h target	Reindex from approved source artifacts; block affected research while index incomplete
Telemetry	RPO <=1 h target	Regional workspace/exports as approved; telemetry loss does not erase audit history

Cross-region evidence copying is allowed only under an explicit residency decision. If region-exclusive processing/storage is required, disable it and redesign RPO/RTO accordingly. GZRS/geo-backup replication alone is asynchronous and must not be represented as a guaranteed five-minute artifact RPO. The proposed verified second-account copy provides a clear durability acknowledgement for finalized evidence but adds latency and cost. Preserve holds/retention on each destination; source immutability does not automatically configure destination retention.

Service Bus offers both message-data Geo-Replication and metadata-only Geo-Disaster Recovery. This baseline can rebuild transport from recovered WorkItems; if message preservation is required, select and test data Geo-Replication rather than assuming a metadata alias protects queued messages. Either choice still requires fencing and semantic idempotency. [Microsoft: Service Bus reliability](#).

Recovery runbook: declare incident and freeze ingress/dispatch -> fence old stamp through gateway access and a recovery authority epoch -> verify isolation of old writers -> inspect DB replica and Blob durability watermark -> promote or restore DB -> reconnect managed identities/private DNS -> validate keys, releases and policy/revocation data -> verify ledger and referenced artifacts -> rebuild READY dispatches and expired leases -> reconcile vendor operations with unknown outcomes -> run synthetic decision/audit test -> reopen limited analyst traffic -> monitor and document lost/replayed interval. If old-region writers cannot be fenced, do not enable competing writers without an explicit split-brain resolution.

Read-replica lag can lose recent commands even when a vendor performed an effect; reconciliation against provider operation IDs is mandatory. Never resend an irreversible operation solely because its receipt is absent after recovery. Test restore monthly in isolated synthetic environments and regional failover at least quarterly under the approved operating model. RTO/RPO targets remain unproven until timed drills pass.

25. Cost, rollout, and operational ownership

Build the Azure estimate from the selected regional rate card and enterprise agreement. No Azure price quote is implied here. Cost categories: APIM units; three compute trust zones and minimum replicas; primary/control/DR databases; Service Bus Premium; Search replicas; Foundry model tokens or provisioned capacity; storage/versions/retention and second-region copies; private endpoints; Firewall/DNS/hybrid connectivity; telemetry ingestion; evaluation runs; and vendor screening/search licenses.

Model daily spend formula: $(\text{input_tokens}/1,000,000 \times \text{approved_input_rate}) + (\text{output_tokens}/1,000,000 \times \text{approved_output_rate})$, summed per model, plus cached/reasoning/tool charges where applicable. Add vendor charges per query/candidate/document and distinguish Azure invoice from KYC analyst labor. Track cost per completed case, per escalation, per accepted evidence item and by profile/vendor. Configure subscription budgets and alerts at 50/75/90/100% of the approved amount; budget alerts do not automatically stop Azure spend. Runtime reservations enforce per-case limits.

Rollout: synthetic-only dev -> preprod corpus -> shadow on permitted cases with no effective recommendations applied -> analyst-confirmed pilot for one business unit -> 5% eligible traffic -> 25% -> 100% after signed gates. Cohort size is governed by evidence and risk, not elapsed days alone. Begin with at least 100 reviewed pilot cases spanning agreed risk cohorts; extend if the corpus is unrepresentative or error intervals remain too wide. Automatic low-risk disposition stays off until a separately evaluated policy release enables it.

Rollback triggers: any unauthorized or cross-tenant data access, ineffective deterministic prohibition, missing decision evidence, material unexpected outcome, runaway cost, or sustained service-target breach. Stop new affected dispatches, revoke unsafe plan/profile if necessary, redirect new cases to the prior signed plan and/or human processing, and quarantine affected cases for impact analysis. Pointer rollback does not erase accepted history or undo vendor side effects.

Ownership: platform team owns compiler/contracts/kernel/gateways; KYC engineering and policy owners own the domain package; integration owners own vendor mappings/coverage; SRE owns availability/recovery; security owns identity/network/revocation incident response; records owners own retention/holds; KYC operations own review staffing and final business acceptance. Each production alert and policy exception must have an accountable owner and expiry/review date.

26. Risks and production readiness checklist

Risk	Mitigation / evidence required
Foundry route bypasses mandatory APIM	Week-2 network/identity proof; isolated Container Apps executor fallback
Region/model/quota incompatibility	Matrix for every SKU, runtime mode and model; approved quota before dependent milestone
Policy or ownership rules remain unspecified	Production compiler rejects UNSET overlays; synthetic implementation continues
Vendor outage interpreted as clear	Typed failure semantics, mandatory coverage/freshness gates and adversarial fixtures
Agent writes or leaked tenant context	Scoped execution token, resource-role denial, composite foreign keys/RLS and negative tests
Blob/DB inconsistency	Prepare/register protocol, durability receipts, orphan reconciliation, blocked finalization
Privileged ledger tampering	Append-only app roles, signed external WORM exports, sequence/hash verification
Model drift or dependency retirement	Immutable resolution, expiry/retirement monitoring, impact graph and reattestation
Infinite investigation or excessive fanout	Budget reservation, bounded steps, deadlines and termination criteria
Retention blocks required deletion or expires early	Approved category/trigger matrix; per-artifact retain-until and legal-hold runbooks
Regional recovery duplicates external effects	Fencing, semantic receipts, provider reconciliation and timed drills
Human review becomes bottleneck	Pilot queue metrics, staffing model, reason-coded rework and SLA escalation

Production readiness requires: approved D01-D10 decisions; all selected resource configurations validated through IaC; public and bypass paths denied; no unowned policy exemptions; approved data and retention schedule; repeatable signed release; all deterministic safety tests passing; acceptable measured model/vendor quality; complete audit lineage; tested restore and failover; staffed review and on-call queues; documented vendor outage/unknown-effect procedures; cost/quota headroom; rollback tested; and KYC/security/operations acceptance of residual risks.

27. Source traceability and implementation refinements

Source reference	Requirement carried into this plan	Plan sections
architecture 1-7, pages 1-13	Generic runtime, canonical Case, contract-only agent proposals, transactional events	2, 9, 12
architecture 8-12, pages 13-21	Evidence/claims/facts, governed tools/skills, deterministic policy	8, 10, 13, 16
architecture 13-18, pages 21-30	Eight roles, bounded investigation, recommendation/gate/disposition and QA	14-17
architecture 19-22, pages 30-36	Compiled plan, permissions, configuration and context	6, 12-13
architecture 23-29, pages 36-44	Recorder, telemetry, failures, concurrency, idempotency and human action	9, 11, 17, 23
architecture 30-38, pages 44-54	Immutable registry/release, evaluations, security, trust and lineage	10, 12-13, 18, 22
architecture 39-45, pages 54-64	Repository, runtime loop, assumptions/contradictions and domain reuse	14-16, 18-20
Addendum A1-A9, pages 1-12	Azure mapping, Foundry, identity, registry separation and APIM	2-8
Addendum A10-A18, pages 12-20	PostgreSQL, Blob, messaging, outbox and kernel	7, 9-11, 24
Addendum A19-A25, pages 20-26	Connectors, secrets, network, residency and context	5-8, 13
Addendum A26-A32, pages 26-32	Telemetry/recorder, governance, review, regional stamps and tenancy	4, 6, 17, 23-24
Addendum A33-A38, pages 32-39	Registry, CI/CD, runtime authority and noncanonical service state	2-3, 12, 18

Implementation refinements are intentional: store and verify evidence before accepting references; require a proven APIM model route rather than assume one; use a production-supported execution fallback; treat PostgreSQL ledger immutability as incomplete without external controls; distinguish regional recovery from zone HA; do not equate Service Bus metadata DR with message replication; and make jurisdiction/retention/model inputs explicit deployment blockers. These refinements preserve the source architecture while making its operational guarantees testable.

External Microsoft references are linked next to the relevant claims throughout this plan. Source PDF citation placeholders were not reused as verified references. Recheck service documentation and actual subscription support immediately before implementing the proposed infrastructure.